

บทที่ 2

ทฤษฎีที่เกี่ยวข้อง

โครงงานชุดโปรแกรมเน็ตเวิร์กไฟร์วอลล์นี้มีการพัฒนาโปรแกรมส่วนต่างๆ คือ ไฟร์สเตชัน (FireStation), ไฟร์อลาร์ม (FireAlarm), ไฟร์สกรีน (FireScreen), ไฟร์เบรก (FireBreak) และ ล็อกมอนิเตอร์ (LogMonitor) ซึ่งในแต่ละส่วนนี้ก็จะมิตฤษฎีที่เกี่ยวข้องอยู่หลายอย่างด้วยกันทั้งทฤษฎีในการพัฒนาโปรแกรมและการนำโปรแกรมมาใช้งานร่วมกันดังที่จะกล่าวถึงต่อไปนี้

2.1 ไฟร์วอลล์

ไฟร์วอลล์เป็นเครื่องมือรักษาความปลอดภัยที่ทำงานในเชิงป้องกันโดยทำหน้าที่ควบคุมการเข้าถึงเน็ตเวิร์ก ซึ่งแพ็กเก็ตที่สามารถผ่านเข้า-ออกเน็ตเวิร์กได้นั้น จะต้องเป็นแพ็กเก็ตที่ไฟร์วอลล์เห็นว่ามีความปลอดภัยโดยอาศัยการเปรียบเทียบกับคุณสมบัติของแพ็กเก็ตที่จะผ่านไฟร์วอลล์กับกฎที่ได้กำหนดไว้เป็นพื้นฐาน

ไฟร์วอลล์สามารถแบ่งได้หลายชนิดและหลายประเภทแต่ถ้าคำนึงถึงลักษณะการทำงานของไฟร์วอลล์ที่ใช้ในการตรวจสอบ และควบคุมสามารถแบ่งไฟร์วอลล์ได้เป็น 3 ประเภท ดังต่อไปนี้คือ

1. แพ็กเก็ตฟิลเตอร์ (Packet Filtering)
2. แอปพลิเคชันพร็อกซี (Application Proxy)
3. สเตตฟูลอินสเปกชัน (Stateful Inspection)

2.1.1 แพ็กเก็ตฟิลเตอร์ (Packet Filtering)

เป็นลักษณะการทำงานโดยทั่วไปของไฟร์วอลล์ที่ใช้ควบคุมทราฟฟิคโดยอาศัยการตรวจสอบข้อมูลที่ปรากฏอยู่ในแพ็กเก็ตเฮดเดอร์ เช่น แอดเดรสต้นทาง (Source Address) แอดเดรสปลายทาง (Destination Address) พอร์ต (Port) โพรโตคอล (Protocol) เป็นต้น ซึ่งจากข้อมูลเหล่านี้จะสามารถนำมาใช้เป็นเงื่อนไขสำหรับควบคุมการเข้าออกของข้อมูลได้ โดยการพิจารณาข้อมูลทั้งหมดให้เป็นไปตามกฎที่ระบุไว้ ซึ่งเรียกว่า แอ็กเซสรูล (Access Rules) หรือ กฎของการควบคุมการผ่านการเข้าออกของแพ็กเก็ต โดยทั่วไปรูปแบบของแอ็กเซสรูลเบื้องต้นจะเป็นดังนี้

ตารางที่ 2.1 แสดงรูปแบบของแอ็กเซสรูลเบื้องต้น

Source Address	Destination Address	Protocol	Service (Dst. Port)	Action
----------------	---------------------	----------	---------------------	--------

โดยข้อมูลทั้งหมดจะเป็นเสมือนตัวแปรที่จะนำมาเปรียบเทียบกับค่าที่ระบุไว้ในแอคเชสรูล ที่ละค่าเงื่อนไขในการเปรียบเทียบของแต่ละตัวจะเป็นตรรกะ และในส่วนของฟิลด์สุดท้าย “Action” หมายถึงสิ่งที่ไฟร์วอลล์จะกระทำเมื่อค่าในแฟล็กเก็ทนั้นตรงกับเงื่อนไข ตัวอย่างเช่น

ตารางที่ 2.2 ตัวอย่างของการตั้งค่าแอคเชสรูลของไฟร์วอลล์

Source Address	Destination Address	Protocol	Service (Dst. Port)	Action
161.246.5.50	ANY	TCP	25	ACCEPT

จากการตั้งแอคเชสรูลเช่นนี้จะหมายความว่าอนุญาตให้แฟล็กเก็ทที่มีต้นทาง IP Address 161.246.5.50 และปลายทางใดๆ ที่ใช้โปรโตคอล TCP หมายเลขพอร์ตปลายทาง 25 ผ่านไฟร์วอลล์ได้ หากไฟร์วอลล์มีแอคเชสรูลนี้เพียงข้อเดียวก็เท่ากับอนุญาตให้โฮสต์เพียงโฮสต์เดียวคือโฮสต์ที่มี IP Address 161.246.5.50 เท่านั้นที่สามารถใช้บริการ SMTP (TCP พอร์ต 25) ไปยังโฮสต์อื่นที่อยู่อีกฟากหนึ่งของไฟร์วอลล์ได้

2.1.2 สเตทฟูลอินสเปกชัน (Stateful Inspection)

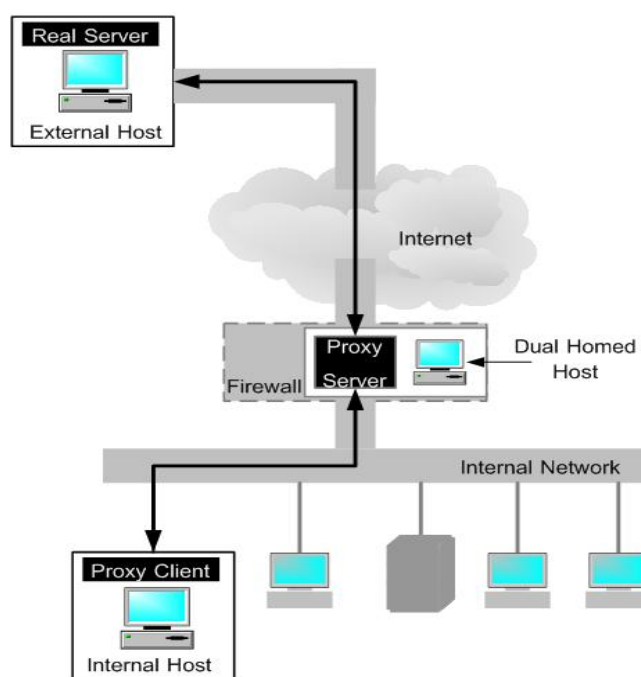
สเตทฟูลอินสเปกชันไฟร์วอลล์ เป็นไฟร์วอลล์ที่ทำการควบคุมทราฟฟิกโดยใช้หลักการของแฟล็กเก็ทฟิเตอร์ และการกำหนดแอคเชสรูลเช่นเดียวกัน แต่สเตทฟูลอินสเปกชัน มีความสามารถที่เพิ่มจากแฟล็กเก็ทฟิเตอร์ คือสามารถฟิเตอร์แบบมองสถานะและภาพรวมได้ ในการพิจารณาว่าจะยอมให้แฟล็กเก็ทผ่านไปได้หรือไม่ นั้น แทนที่จะดูข้อมูลจากเฮดเดอร์เพียงอย่างเดียว ไฟร์วอลล์แบบสเตทฟูลจะมีการบันทึกข้อมูลเกี่ยวกับการเชื่อมต่อที่เกิดขึ้นลงในตารางเก็บสถานะ (state table) ก่อนที่จะส่งแฟล็กเก็ทนั้นไปยัง IP stack ตารางเก็บสถานะนี้จะมีส่วนที่ใช้บันทึกข้อมูลสำหรับแต่ละการเชื่อมต่อที่ถูกต้อง โดยปกติจะเก็บข้อมูล ไอพีของต้นทางและปลายทาง, โปรโตคอล, พอร์ต และแฟล็ก แต่มีไฟร์วอลล์บางยี่ห้อที่เก็บข้อมูลลำดับการส่งข้อมูล (sequence number) เพิ่มด้วย เพื่อใช้ในการตรวจสอบแฟล็กเก็ทที่กำลังจะเข้ามาและป้องกันการขโมยเซสชัน (session hijacking)

และเมื่อได้รับแฟล็กเก็ทใหม่เข้ามา ไฟร์วอลล์แบบสเตทฟูลจะทำการตรวจสอบข้อมูลกับตารางเก็บสถานะว่าเป็นส่วนของการเชื่อมต่อที่สร้างไว้แล้วหรือไม่ โดยจะพิจารณาจากข้อมูล ไอพี และพอร์ตของต้นทางและปลายทาง จะต้องสอดคล้องกับตารางเก็บสถานะ ซึ่งถ้าเป็นส่วนหนึ่งของการเชื่อมต่อจริงก็ไม่มีปัญหาใดๆ ที่ต้องตรวจสอบซ้ำอีก

อย่างไรก็ตาม สเตทฟูลไฟร์วอลล์นี้ยังไม่สามารถป้องกันการโจมตีที่แทรกซึมมาจากการเชื่อมต่อตามปกติได้ เช่น โพรโตคอล FTP นั้น แม้ว่าไฟร์วอลล์แบบสเตทฟูลจะมีการติดตามให้มีการเปิดพอร์ต 20 และ 21 อย่างถูกต้อง แต่ถ้าหากในเนื้อหาที่ส่งมาเป็นสิ่งที่ประสงค์ร้าย ก็จะไม่สามารถรับรู้และป้องกันการโจมตีแบบนี้ได้

2.1.3 แอปพลิเคชันพร็อกซี (Application Proxy)

พร็อกซี (Proxy) หรือ แอปพลิเคชันเกตเวย์ (Application Gateway) เป็นแอปพลิเคชันโปรแกรมที่ทำงานอยู่บนไฟร์วอลล์ ที่ตั้งอยู่ระหว่างเน็ตเวิร์ค 2 เน็ตเวิร์ค ทำหน้าที่เพิ่มความปลอดภัยของระบบเครือข่ายโดยการควบคุมการเชื่อมต่อระหว่างเครือข่ายภายในกับภายนอก พร็อกซี จะช่วยเพิ่มความปลอดภัยได้มากเนื่องจากการตรวจสอบข้อมูลถึงในระดับของแอปพลิเคชันเลเยอร์ (Application Layer) เมื่อไคลเอนต์ (Client) ต้องการใช้บริการจากภายนอก ไคลเอนต์จะทำการติดต่อไปยังพร็อกซีก่อน แล้วพร็อกซีจึงจะติดต่อไปยังเครื่องปลายทางให้แล้วจะมีการเชื่อมต่อ (connection) 2 การเชื่อมต่อ คือ ไคลเอนต์ กับ พร็อกซี และ พร็อกซี กับเครื่องปลายทาง โดยที่พร็อกซีจะทำหน้าที่รับข้อมูลและส่งข้อมูลให้ใน 2 ทิศทาง ทั้งนี้พร็อกซีจะทำหน้าที่ในการตัดสินใจว่าจะให้มีการเชื่อมต่อกันหรือไม่ หรือจะส่งต่อแพ็คเก็ตให้หรือไม่



รูปที่ 2.1 แสดงการใช้ Dual-homed Host เป็น พร็อกซีเซิร์ฟเวอร์ (Proxy Server)

2.2 เทคโนโลยีแอคทีฟไดเรกทอรี (Active Directory)

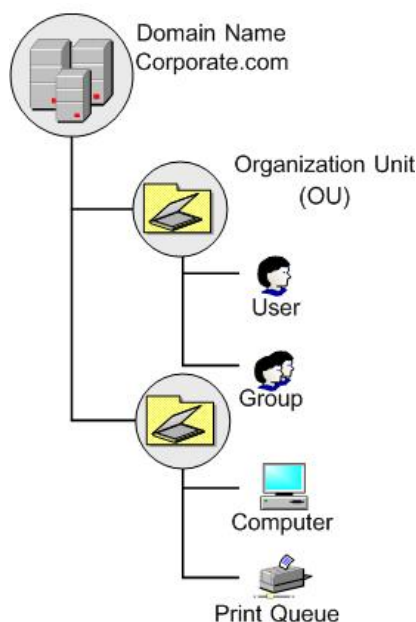
แอคทีฟไดเรกทอรีเป็นเทคโนโลยีบริการไดเรกทอรีของไมโครซอฟท์ เป็นบริการที่เกี่ยวข้องกับการจัดเก็บข้อมูลของทรัพยากรที่มีอยู่ในเครือข่ายลงในไดเรกทอรี โดยแอคทีฟไดเรกทอรีจะมีฐานข้อมูลในตัวเองสำหรับจัดเก็บรายละเอียดของทรัพยากรนั้น

2.2.1 ส่วนประกอบของแอคทีฟไดเรกทอรี

แอคทีฟไดเรกทอรีจะแบ่งการทำงานออกเป็น 2 ส่วน คือ

- Active Directory Service เป็นเครื่องมืออำนวยความสะดวกในการเรียกค้น จัดการกับ บัญชีรายชื่อของผู้ใช้และรายชื่อกลุ่ม และสามารถค้นหารายชื่อทรัพยากรในระบบที่มี คุณสมบัติตามที่ผู้ใช้ต้องการ ซึ่งแอคทีฟไดเรกทอรีเซิร์ฟเวอร์จะเข้าไปค้นหาข้อมูลจากแอคทีฟไดเรกทอรีดาต้าเบสแล้วแสดงรายละเอียดต่างๆขึ้นมา
- Active Directory Database ทำหน้าที่ในการจัดเก็บข้อมูลในระบบไดเรกทอรี โดยการเข้าถึงดาต้าเบสจะต้องผ่าน การล็อกอินจึงจะมีสิทธิในการใช้งาน

2.2.2 ข้อมูลที่เก็บอยู่ใน Active Directory Database



รูปที่ 2.2 โครงสร้างโดยรวมของแอคทีฟไดเรกทอรีดาต้าเบส (Active Directory Database)

- ออบเจกต์ต่างๆที่ใช้เป็นตัวแทนของทรัพยากรในระบบเครือข่าย เช่น ออบเจกต์ที่เป็นตัวแทนของแชร์โฟลเดอร์(Shared Folder Object) ออบเจกต์ที่เป็นตัวแทนของเครื่องพิมพ์
- คอนเทนเนอร์ต่างๆที่เป็นของระบบตั้งแต่เริ่มต้นเช่นคอนเทนเนอร์ที่ชื่อUsers, Computers และ Built-in
- คอนเทนเนอร์พิเศษที่เรียกว่า Organizational Unit (OU)
- System Configuration ต่างๆ ของโครงสร้าง Active Directory ทั้งหมด เช่น Schema , Global Catalog

- เป็นที่เก็บ Group Policy Object (GPO) เพื่อใช้ในการควบคุม และจัดการเครื่องคอมพิวเตอร์ ของผู้ใช้
- อื่นๆอีกมากมายแล้วแต่จะขยายเพิ่มเติมในอนาคตเช่นออบเจกต์ที่เป็นตัวแทนของ อุปกรณ์สื่อสารในระบบเน็ตเวิร์ก

2.2.3 สกีม่า (Schema)

เป็นฐานข้อมูลส่วนย่อยที่เก็บอยู่ในแอคทีฟไดเรกทอรีดาต้าเบส ซึ่งทำหน้าที่เก็บรวบรวมข้อกำหนดเกี่ยวกับคลาสของออบเจกต์ทุกคลาส เช่น ออบเจกต์ที่อยู่ในแต่ละคลาสจะต้องมีแอตทริบิวต์อะไร ค่าของแต่ละแอตทริบิวต์มีคุณสมบัติเป็นอะไร Schema สามารถเพิ่มขยายได้โดยผู้บริหารระบบเครือข่าย ได้แก่ การเพิ่มคลาสประเภทใหม่ๆ เข้าไป หรือการเพิ่ม แอตทริบิวต์ใหม่ให้กับคลาสเดิมที่มีอยู่แล้ว

2.2.4 การติดต่อกับ Active Directory (LDAP Protocol)

LDAP (Lightweight Directory Access Protocol) เป็นโปรโตคอลที่พัฒนามาจาก X.500 ซึ่งใช้ในการเข้าถึงและอัปเดตข้อมูลของไดเรกทอรี และเป็นโปรโตคอลมาตรฐานสำหรับการสืบค้นหรือเปลี่ยนแปลงข้อมูลบนบริการไดเรกทอรี โดย LDAP จะทำงานอยู่บนโปรโตคอล TCP/IP อีกทีหนึ่ง ซึ่งไดเรกทอรีจะมีรูปแบบเป็นโครงสร้างต้นไม้ที่แต่ละ entry จะประกอบไปด้วยชุดของ attribute และค่าของ attribute นั้นๆ ซึ่งบริการไดเรกทอรีของไมโครซอฟท์ (Microsoft Active Directory Service) ก็ทำงานอยู่บนโปรโตคอล LDAP เช่นเดียวกัน

ในส่วนการติดต่อระหว่างไคลเอนต์ที่ต้องการใช้บริการของเซิร์ฟเวอร์ LDAP มีหลักการเบื้องต้นดังนี้ LDAP ไคลเอนต์ทำการเริ่มต้น LDAP session โดยเชื่อมต่อเข้ามายัง LDAP เซิร์ฟเวอร์ ซึ่งปกติจะใช้งานพอร์ตหมายเลข 389 (636 สำหรับ SSL/TLS) หลังจากนั้นไคลเอนต์ก็จะส่งคำสั่งต่างๆไปยังเซิร์ฟเวอร์ซึ่งจะส่งคืนค่าที่ต้องการให้กับทางไคลเอนต์โดยมีข้อนำสังเกตที่ทางไคลเอนต์ไม่มีความจำเป็นที่จะต้องรอนกว่าเซิร์ฟเวอร์จะส่งคืนค่ามาแล้วจึงส่งคำสั่งถัดไปสามารถส่งคำสั่งต่อเนื่องได้เรื่อยๆ เช่นเดียวกันทางเซิร์ฟเวอร์อาจส่งค่ากลับมาในลำดับใดๆก็ได้

Directory structure ของ แอคทีฟไดเรกทอรี

'directory' เป็นโครงสร้างต้นไม้ (tree) ของ entry ในไดเรกทอรี

'entry' ประกอบไปด้วยชุดของ attribute

'attribute' จะต้องมีชื่อและมี value 1 ค่าหรือมากกว่า และถูกกำหนดไว้ใน schema

โดยแต่ละ entry ต้องมีชื่อที่สามารถระบุได้ชัดเจนถึงแต่ละ entry เรียกว่า Distinguished Name (DN)

โดยแต่ละ entry จะมีลักษณะดังนี้เมื่อแสดงในรูปแบบของไฟล์ LDIF

```

dn: cn=John Doe,dc=example,dc=com
cn: John Doe
givenName: John
sn: Doe
telephoneNumber: +1 555 6789
telephoneNumber: +1 555 1234
mail: john@example.com
manager: cn=Barbara Doe, dc=example, dc=com
objectClass: inetOrgPerson
objectClass: organizationalPerson
objectClass: person
objectClass: top

```

dn เป็นชื่อของ entry เอง ไม่ได้เป็น attribute ใด attribute หนึ่งใน entry นั้น จากตัวอย่างข้างต้นจะมี "cn=John Doe" เป็น RDN ของ entry และ "dc=example, dc=com" เป็น dn ของ parent entry ส่วนที่เหลือจะแสดง attribute และ value ที่เก็บไว้ เช่น "cn" สำหรับ common name และ "dc" สำหรับ domain component ซึ่ง value ก็เป็นเพียงชุดของ string ธรรมดาๆ

คำสั่งพื้นฐานมีดังนี้

- Bind : พิสูจน์สิทธิ์และระบุเวอร์ชันของ LDAP protocol
- Search : ค้นหาข้อมูลที่ต้องการในไดเรกทอรี
- Compare : ทดสอบว่า entry ดังกล่าวมี attribute value ที่ต้องการหาหรือไม่
- Add a new entry : เพิ่มค่า entry ใหม่
- Delete an entry : ลบ entry
- Modify an entry : แก้ไขค่า entry
- Modify DN : ย้ายที่หรือเปลี่ยนชื่อ entry
- Start TLS : ใช้งานการเชื่อมต่อแบบ TLS
- Abandon : ยกเลิกการร้องขอที่ผ่านมา
- Extended Operation : คำสั่งต่างๆไปใช้ร่วมกับคำสั่งอื่นๆ
- Unbind : ยกเลิกการเชื่อมต่อ (ไม่ได้เป็นคำสั่งตรงข้ามกับ Bind แต่อย่างใด)

ตัวอย่างการเข้าถึง organizational unit

```
Set ou = GetObject("LDAP://host1/OU=Sales,DC=ArcadiayBay,DC=COM")
```

```
For each obj in ou
```

```
    Debug.Print obj.Name
```

```
Next
```

ตัวอย่างนี้เป็นการแสดงรายชื่อของ Object ที่อยู่ใน Organizational unit ที่ชื่อว่า Sales ในโดเมน ArcadiayBay.com

2.3 netfilter/iptables

netfilter/iptables เป็นโมดูลสำหรับกรองแพ็คเก็ตซึ่งมีอยู่ในระบบปฏิบัติการ GNU/Linux เคอร์เนลตั้งแต่เวอร์ชัน 2.4.x จนถึงปัจจุบันที่เวอร์ชัน 2.6.x โดยจัดเป็นยุคที่ 3 ของไฟร์วอลล์บนลินุกซ์นับตั้งแต่ ipfwadm ซึ่งมีในลินุกซ์เคอร์เนล 2.0.x (ipfwadm พัฒนามาจาก ipfw ของ BSD) จากนั้นจึงกลายมาเป็น ipchains ในลินุกซ์เคอร์เนล 2.2.x โดยมี Rusty Russel เป็นแกนหลักในทีมพัฒนา และได้พัฒนาต่อมาจนกลายมาเป็น netfilter/iptables ในที่สุด

netfilter นั้นเป็นชื่อของโค้ดในส่วนที่ทำหน้าที่กรองแพ็คเก็ต โดยต่อไปนี้จะเรียกรวมว่าเป็น iptables ซึ่งเป็นคำสั่งในการเรียกใช้งาน netfilter/iptables

iptables เป็นไฟร์วอลล์ที่มีความสามารถในการกรองแพ็คเก็ตแบบสเตทฟูล อินสเปกชันสามารถทำ Network Address Translation (NAT) ได้ และสามารถทำ packet mangling เช่นการแก้ไขค่า ToS หรือ Mark ได้ เป็นต้น

ในโครงการนี้จะให้ความสำคัญไปที่ความสามารถในการกรองแพ็คเก็ตของ iptables เป็นสำคัญซึ่งเป็นความสามารถสำคัญของ iptables ในการใช้งานเป็นไฟร์วอลล์

2.3.1 การทำงานเบื้องต้นของ iptables

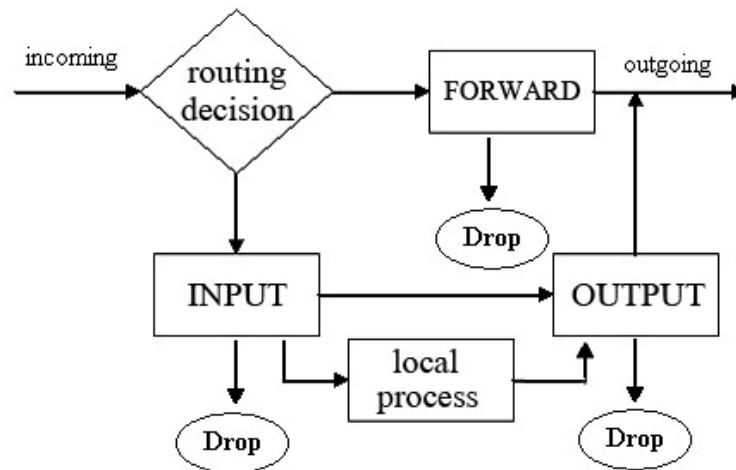
แพ็คเก็ตที่ผ่านเข้ามายังเครื่องไฟร์วอลล์จะผ่านเข้าไปยังเทเบิลต่างๆของ iptables ซึ่งแต่ละเทเบิลก็จะมีหน้าที่ต่างกันไปโดยแต่ละเทเบิลจะมีหลาย chain สำหรับแพ็คเก็ตรูปแบบต่างๆ โดยมีรายละเอียดดังต่อไปนี้

■ Tables

iptables มีเทเบิลที่สร้างไว้เรียบร้อยแล้วทั้งหมด 3 เทเบิล คือ

1. Filter Table

ใช้สำหรับกรองแพ็คเก็ตมี chain ที่ถูกสร้างไว้แล้วอยู่ด้วยกัน 3 chain คือ INPUT, OUTPUT, FORWARD เป็นตารางที่มีส่วนร่วมในการใช้งานมากที่สุดของ iptables เป็นจุดที่ใช้ในการตรวจสอบควบคุมการผ่านเข้าออกของแพ็คเก็ต โดยการไหลเวียนของแพ็คเก็ตเฉพาะในส่วน of filter table แสดงให้เห็นได้ดังรูปที่ 2.2 เมื่อแพ็คเก็ตผ่านเข้ามาในระบบจะเข้าไปยัง routing decision เพื่อตัดสินใจว่าแพ็คเก็ตจะถูกส่งไปที่ใด



รูปที่ 2.3 การเดินทางของแพ็คเก็ตใน Filter Table

กรณีที่แพ็คเก็ตถูกส่งผ่านไปยังเครื่องอื่นแพ็คเก็ตนั้นจะผ่านเข้าไปใน FORWARD chain ก่อนที่จะส่งผ่านไปยังปลายทางที่ระบุหรืออาจจะถูก drop ทั้งตามแต่กฎที่ตั้งไว้

ถ้าแพ็คเก็ตนั้นมีเป้าหมายเป็นเครื่องปัจจุบัน แพ็คเก็ตนั้นจะผ่านเข้าไปใน INPUT chain โดยที่จะถูกนำไปประมวลผลใน userspace หรืออาจจะถูก drop ทั้งตามแต่กฎที่ตั้งไว้

กรณีที่แพ็คเก็ตถูกสร้างจากเครื่องปัจจุบัน แพ็คเก็ตจะผ่านเข้าไปใน OUTPUT chain ก่อนที่จะถูกส่งออกไปหรืออาจจะถูก drop ทั้งตามแต่กฎที่ตั้งไว้

2. Nat Table

ใช้สำหรับการแปลงแอดเดรส (Network Address Translation), คู่มือในส่วนที่เกี่ยวข้องกับการแปลงแอดเดรสทั้ง SNAT และ DNAT รวมถึงการทำ MASQUERADE และการทำ REDIRECT มี 3 built-in chain

- 1) PREROUTING ทำการแปลงแพ็คเก็ตที่เข้ามาในส่วน of DNAT และดูแลเรื่อง REDIRECT
- 2) POSTROUTING ทำการแปลงแพ็คเก็ตในส่วน of SNAT และดูแลเรื่อง REDIRECT
- 3) OUTPUT ทำการแปลงแพ็คเก็ตที่จะส่งออกไปในส่วน of DNAT และดูแลเรื่อง REDIRECT

3. Mangle Table

เป็นตารางที่ใช้ดูแลการเปลี่ยนแปลงหรือแก้ไขแพ็กเก็ตเช่น เปลี่ยนค่า TTL, ToS, MARK ซึ่งปกติจะใช้ในการทำ routing และ forwarding ที่มีความซับซ้อนสูง มี 2 built-in chain คือ

- 1) PREROUTING chain ทำการเปลี่ยนแปลงแพ็กเก็ตที่เข้ามาก่อนที่จะทำการ routing decision
- 2) OUTPUT chain ทำการเปลี่ยนแปลงแพ็กเก็ตที่จะส่งออกไปจากภายในเครือข่าย

2.3.2 การสร้างกฎของ iptables

รูปแบบของคำสั่งในการใช้งาน iptables

iptables [table] <command> <match> <target/jump>

iptables มีรูปแบบการใช้งานดังข้างต้น โดยกฎที่เขียนขึ้นจะเป็นตัวบอกเคอร์เนลว่าให้กระทำการอย่างไร (action) ในกรณีที่พบแพ็กเก็ตที่ตรงตามกฎที่ระบุไว้

■ Command

- A เพิ่มกฎใหม่ต่อท้าย chain (Append rule)
- D ลบกฎ (Delete rule)
- I เพิ่มกฎใหม่ใน chain (Insert rule)
- R แทนที่กฎเดิมด้วยกฎใหม่ (Replace rule)
- L แสดงกฎใน chain (ถ้าไม่ระบุ chain จะแสดงกฎใน filter table ทั้งสาม built-in chain)
- F ลบกฎทั้งหมดใน chain ทิ้ง
- Z ใช้ reset byte counter สำหรับทุกกฎใน chain ที่กำหนด
- N ใช้สร้าง chain ใหม่
- X ลบ chain ใ้กับ user-defined chain ที่ไม่มีกฎ แต่ไม่สามารถลบ built-in chain ได้
- P เปลี่ยน default policy ของ chain ค่าที่ใช้กับcommand นี้คือ ACCEPT, DROP
- E ใช้เปลี่ยนชื่อ chain ใหม่

ซึ่งการใช้ command ข้างต้นนั้นสามารถใช้ร่วมกับออปชั่นบางอย่างได้ คือ

-v (--verbose) ใช้ร่วมกับ -L, -A, -I, -D, -R เพื่อให้แสดงจำนวน byte ที่ match กับ กฎออกมา (หน่วยที่แสดงออกมานั้นอาจจะเป็น K, M, G)

-x (--exact) ใช้ร่วมกับ -L และ -v เพื่อให้แสดงจำนวนแพ็กเก็ตและจำนวนของ byte ข้อมูลที่ match โดยไม่แสดงผลในหน่วยของ K, M, G

-n (--numeric) ใช้ร่วมกับ -L เพื่อสั่งให้ iptables แสดงข้อมูล ip address และ พอร์ต เป็นตัวเลขเท่านั้น

--line-numbers ใช้ร่วมกับ -L เพื่อแสดงเลขบรรทัดของกฎซึ่งตัวเลขที่แสดงนี้จะสามารถใช้ได้กับคำสั่งแทรกกฎ ที่ระบุเป็นลำดับที่ของกฎ

- Match

- การระบุ source, destination IP address

สามารถระบุ source ip address ของแพ็คเก็ตโดยใช้ -s หรือ --source หรือ --src และ destination ip address ใช้ -d หรือ --destination หรือ --dst ในการระบุไอพีแอดเดรสนั้นสามารถทำได้ 3 แบบด้วยกันคือ

1. ใช้ชื่อเต็มแทน เช่น localhost หรือ www.ce.kmitl.ac.th
2. ระบุไอพีแอดเดรสโดยตรง เช่น 127.0.0.1 หรือ 161.246.4.7
3. ระบุเป็นกลุ่มของไอพีแอดเดรส เช่น 161.246.5.0/24 ซึ่งหมายถึงไอพีแอดเดรสตั้งแต่ 161.246.5.0 – 161.246.5.255 หรือ 161.246.5.0 /255.255.255.0 แทน 161.246.5.0 /24 ได้

- การทำ Inversion

ทำได้โดยใช้เครื่องหมาย ! นำหน้า argument ที่ต้องการ (! หมายถึง NOT) เช่น -p ! TCP

- การระบุโปรโตคอล

สามารถระบุโปรโตคอลที่ต้องการได้ดังนี้คือ TCP, UDP, ICMP และสามารถใช้ได้ทั้งตัวอักษรเล็กหรือใหญ่ (ใช้ได้ทั้ง tcp และ TCP) เช่น -p TCP หรือ -p ! tcp

- การระบุ interface

-i หรือ --in-interface ตามด้วยชื่อ interface ใช้เพื่อระบุ incoming interface ซึ่งหมายถึงว่าแพ็คเก็ตที่จะ match กับ rule นี้ต้องเข้ามาจาก interface ที่กำหนด เช่น -i eth0 หมายความว่า ทุกแพ็คเก็ตที่เข้ามาทาง eth0 จะ match กับกฎนี้

-o หรือ --out-interface ตามด้วยชื่อของ interface ใช้เพื่อระบุ outgoing interface ซึ่งหมายถึงว่าแพ็คเก็ตที่จะ match กับ rule นี้ กำลังจะเดินทางผ่าน interface ที่ระบุไว้ เช่น -o eth1 หรือ -o ! eth1 จะ match กับกฎนี้

- fragment packet

ในการส่งข้อมูลผ่านเครือข่ายนั้นเป็นเรื่องปกติที่จะเกิดการ fragment ของแพ็คเก็ตเนื่องจากขนาดของแพ็คเก็ตมีขนาดใหญ่เกินไปที่จะส่งไปในครั้งเดียว จำเป็นต้องมีการแบ่งแพ็คเก็ตออกเป็นหลายๆชิ้นทยอยส่งไป ซึ่งเรียกกันว่าการทำ fragment โดยเครื่องปลายทางจะทำหน้าที่ประกอบ fragment แพ็คเก็ตรวมกันเป็นแพ็คเก็ตที่สมบูรณ์ดังเดิม ข้อมูลที่เป็น fragment แพ็คเก็ตจะมีเฮดเดอร์ที่สมบูรณ์แค่แพ็คเก็ตแรกเท่านั้นแพ็คเก็ตที่ตามมาจะมีเฮดเดอร์แค่บางส่วนคือ ไอพีแอดเดรส ไม่มีข้อมูลของโปรโตคอลแบบมาด้วย ดังนั้นการตรวจสอบข้อมูลเฮดเดอร์ของ TCP, UDP, ICMP จึงไม่สามารถทำได้ในแพ็คเก็ตที่สองเป็นต้นมา

โดยปกติแล้วมักจะปล่อยให้ fragment แพ็คเก็ตผ่านไป เนื่องจากถ้าสามารถ DROP ตัว fragment แพ็คเก็ต ตัวแรกได้แล้ว มันก็ไม่สามารถถูกประกอบที่เครื่องปลายทางได้ แต่ทั้งนี้ fragment แพ็คเก็ต ที่ถูกปล่อยไปดังกล่าวอาจจะทำให้เครื่องที่ได้รับไม่สามารถทำงานต่อได้

- TCP extension

ถ้ามีการเรียกใช้ `-p tcp` ตัว TCP extension ก็จะถูกโหลดมาใช้งานโดยอัตโนมัติ โดยมีออปชันให้เลือกใช้งานดังนี้

`--tcp-flags mask flags` : mask นั้นหมายถึง flag ที่ต้องการตรวจสอบ และ flag เป็นตัวที่บ่งชี้ว่า flag ใดต้องถูก set บ้าง

`--source-port` หรือ `--sport` สามารถใช้ได้ทั้งตัวเลขและตัวอักษร ระบุเป็น port เดี่ยว หรือช่วงของ port ได้

`--destination-port` หรือ `--dport` มีรูปแบบการใช้งานเช่นเดียวกันกับ `--sport`

- UDP extension

เช่นเดียวกับ TCP ตัว UDP extension มีออปชันให้เลือกใช้เพียงแค่ 2 อย่างเท่านั้นคือ `--source-port` (`--sport`) และ `--destination-port` (`--dport`) โดยต้องระบุ `-p udp` ด้วย

- ICMP extension

โดยการระบุ `-p icmp` ก็สามารถใช้งาน ICMP extension ได้ โดยมีออปชันให้เลือกคือ `--icmp-type` เช่น `--icmp-type host-unreachable` (หรือใช้เลข 3 แทนได้) นอกจากนี้ยังสามารถระบุ type/code ได้ เช่น 3/3 ซึ่งหมายถึง port unreachable

- Match Extension

เป็น netfilter package อื่นๆรูปแบบการใช้งานให้ใช้ `-m` แล้วตามด้วย match ที่ต้องการมีออปชันให้เลือกใช้งานดังต่อไปนี้

mac รูปแบบการใช้งาน: `-m mac` ใช้ตรวจสอบ source MAC address ว่าตรงกับค่าที่ระบุไว้หรือไม่ มีประโยชน์สำหรับ *PREROUTING* และ *INPUT chain*

limit รูปแบบการใช้งาน: `-m limit` ใช้เพื่อจำกัดจำนวนของการ match ที่อาจจะมากเกินไปเป็นประโยชน์สำหรับ rule ที่วางไว้ตอนท้ายสุดของ chain (ใช้รวมกันกับ DROP policy) ซึ่งส่วนใหญ่เป็น rule ที่ใช้เก็บข้อมูลลงล็อกไฟล์ ซึ่งถ้าผู้บุกรุกส่งแพ็คเก็ตที่ไม่เข้าข่าย rule ใดๆ ใน chain จนกระทั่งมาถึง rule ที่ทำหน้าที่เก็บล็อกนี้ถ้าแพ็คเก็ตที่เข้ามามีจำนวนมากก็อาจจะทำให้ฮาร์ดดิสก์เต็มได้ ดังนั้นจึงต้องใช้จำกัดจำนวนในการเก็บข้อมูลลงล็อก ซึ่งมีออปชันให้ใช้งานดังนี้คือ

State Match รูปแบบการใช้งานคือ `-m state` หรือ `--match state` เป็นโมดูลที่ใช้ประโยชน์ได้เป็นอย่างดี มีออปชันให้ใช้งานดังนี้

NEW – แพ็คเก็ตที่เป็นตัวสร้างการเชื่อมต่อใหม่

ESTABLISHED – แพ็คเก็ตที่เกี่ยวข้องกับการเชื่อมต่อที่สร้างไว้แล้ว

RELATED - แพ็คเก็ตที่เกี่ยวข้องกับการเชื่อมต่อที่สร้างไว้แล้ว แต่ไม่ใช่ส่วนหนึ่งส่วนใดของการเชื่อมต่อ

INVALID – เป็นแพ็คเก็ตที่ไม่เกี่ยวข้องกับส่วนอื่นเลย

- Target

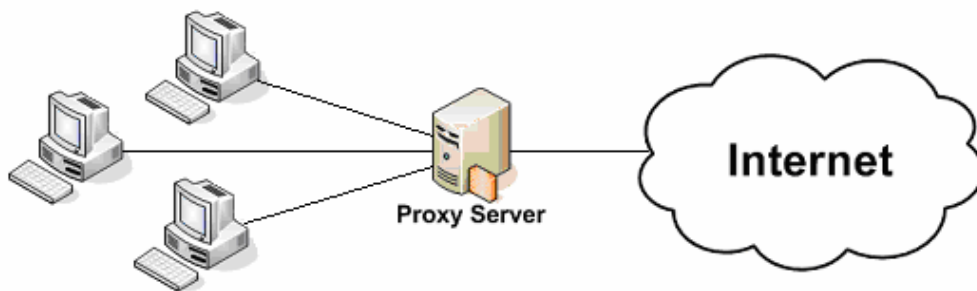
เป็นส่วนที่ระบุ action กับแพ็คเก็ตต่างๆที่ match กับกฎที่ได้ตั้งขึ้นซึ่งมี target ในแบบต่างๆ ดังนี้

- ACCEPT อนุญาตให้แพ็คเก็ตที่ match กับกฎนี้สามารถผ่านไป
- DROP แพ็คเก็ตที่ match กับกฎนี้ให้ทำการ Drop ทิ้งหรือไม่ให้ผ่าน
- LOG เป็นโมดูลที่มีความสามารถในการเก็บข้อมูลลงล็อก
- REJECT คล้ายกับ DROP แต่จะมีการส่ง ICMP port unreachable กลับไปยังผู้ส่ง
- RETURN ออกจาก chain ปัจจุบันกลับไปยัง chain ที่ทำการเรียกมา
- QUEUE เป็น chain พิเศษใช้สำหรับส่งต่อแพ็คเก็ตไปยังแอปพลิเคชันที่เขียนขึ้นมารองรับ โดยเฉพาะ โดยจะต้องมี queue handler และแอปพลิเคชันเป็นส่วนประกอบที่จะทำงานร่วมกัน
- User-defined chain ผู้ใช้สามารถสร้าง chain ใหม่ได้โดยต้องใช้ตัวอักษรตัวเล็กทั้งหมด สำหรับ chain ที่สร้างขึ้นใหม่ เมื่อแพ็คเก็ต match กับกฎที่เป็น user-defined chain แพ็คเก็ตจะถูกนำไปตรวจสอบใหม่โดย user-defined chain นั้นๆและถ้าใน chain ไม่มีการตัดสินใจใดๆตัวแพ็คเก็ตก็สามารถย้อนกลับมายังกฎถัดไปใน chain เริ่มต้นได้

2.4 พร็อกซี

2.4.1 เว็บพร็อกซี (Regular Webproxy)

เว็บพร็อกซีมีลักษณะการใช้งานคือ การอนุญาตให้เครื่องไคลเอ็นต์ภายในเครือข่ายสามารถติดต่อกับอินเทอร์เน็ตได้โดยผ่านเว็บพร็อกซี โดยเว็บพร็อกซีจะรองรับการร้องขอจากเครื่องไคลเอ็นต์ภายในเครือข่าย แล้วทำการส่งต่อคำร้องขอนี้ไปยังเครื่องเซิร์ฟเวอร์ จากนั้นก็รองรับการตอบกลับของเซิร์ฟเวอร์แล้วทำการส่งต่อคำตอบรับนั้นให้กับไคลเอ็นต์ ซึ่งเว็บพร็อกซีนี้สามารถทำการแคชข้อมูล คือการเก็บสำเนาข้อมูลจากอินเทอร์เน็ตมาไว้ที่เว็บพร็อกซี ทำให้เว็บพร็อกซีนั้นไม่ต้องทำการร้องขอข้อมูลที่เคยทำการการร้องขอไปแล้วซ้ำ สามารถที่จะส่งข้อมูลเหล่านั้นให้กับเครื่องไคลเอ็นต์ที่ทำการร้องขอข้อมูลได้ทันที ทำให้การใช้งานอินเทอร์เน็ตนั้นทำได้รวดเร็วมากขึ้น



รูปที่ 2.4 แสดงตำแหน่งของเว็บพร็อกซี่ในเครือข่าย

ความสามารถและการใช้งานเว็บพร็อกซี่

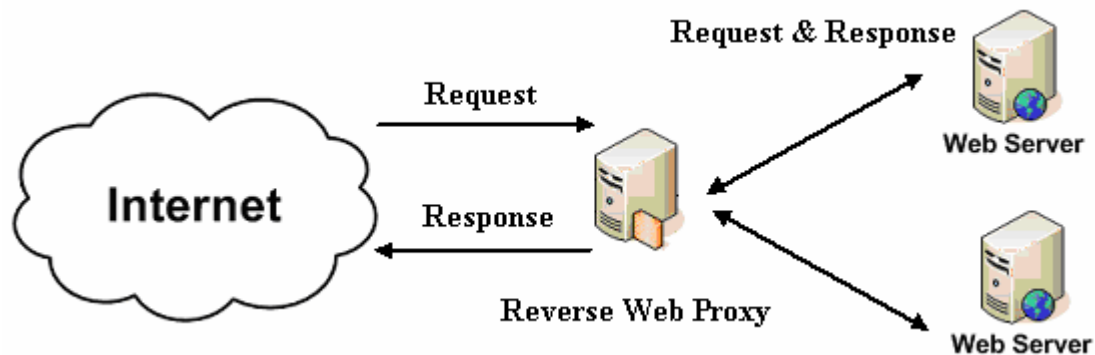
- อนุญาตและจำกัดการใช้งานอินเทอร์เน็ตของเครื่องไคลเอนต์โดยวิธีการตรวจสอบไอพีแอดเดรส
- แคมข้อมูลจากภายนอกให้เครื่องภายในเครือข่ายที่ต้องการข้อมูลที่เหมือนกันเรียกใช้งานได้เร็วขึ้น
- สามารถควบคุมให้การเข้าใช้งานอินเทอร์เน็ตและซบเน็ตที่ต้องการได้โดยกำหนด URL เป็นหลัก
- อนุญาตหรือปฏิเสธการร้องขอจากไคลเอนต์โดยมีรูปแบบเงื่อนไขในการตัดสินใจ
- กำหนด URL ที่จะใช้ในการกรองหรืออนุญาตให้เรียกใช้ผ่านเครื่องเซิร์ฟเวอร์ได้

2.4.2 รีเวิร์สเว็บพร็อกซี่ (Reverse Webproxy)

รีเวิร์สเว็บพร็อกซี่ เป็นพร็อกซี่ที่ทำงานบนฝั่งเซิร์ฟเวอร์แทนที่จะทำงานบนฝั่งไคลเอนต์จึงเรียกว่าเป็นการทำงานแบบรีเวิร์ส รีเวิร์สเว็บพร็อกซี่เป็นแอปพลิเคชันพร็อกซี่สำหรับเซิร์ฟเวอร์ที่ใช้โปรโตคอล HTTP รีเวิร์สเว็บพร็อกซี่จะทำงานอยู่ระหว่างไคลเอนต์กับเว็บเซิร์ฟเวอร์ทำหน้าที่เป็นเกตเวย์ของเว็บเซิร์ฟเวอร์ หรือ ไอพีแอดเดรสที่ใช้สำหรับรับการร้องขอจากภายนอก ทำให้ไคลเอนต์เห็นรีเวิร์สเว็บพร็อกซี่เป็นเครื่องเว็บเซิร์ฟเวอร์ และดูแลทราฟฟิกก่อนที่จะเข้าถึงเว็บเซิร์ฟเวอร์ โดยตรวจสอบดูการร้องขอที่ส่งเข้ามานั้นเคยมีการแคชไว้หรือไม่ถ้ามีอยู่ในแคชก็จะทำการตอบกลับข้อมูลในแคชให้กับไคลเอนต์ ทำให้เว็บเซิร์ฟเวอร์ไม่ต้องสร้างข้อมูลตอบกลับหรือผลลัพธ์ทุกครั้งที่ได้รับการร้องขอ เว้นแต่ข้อมูลประเภท Dynamic ที่จะต้องมีการส่งการร้องขอไปยังเว็บเซิร์ฟเวอร์เพื่อประมวลผลทุกครั้ง โดยก่อนใช้งานรีเวิร์สเว็บพร็อกซี่ต้องมีการกำหนด prefix mapping ให้แกรีเวิร์สเว็บพร็อกซี่ก่อนซึ่ง prefix mapping มี 2 ชนิด คือ

- 1) regular mapping ใช้สำหรับบอกรีเวิร์สเว็บพร็อกซี่ว่า URL prefix ไหนถูกแทนที่และบอก URL ปลายทางจริง

- 2) reverse mapping เป็นส่วนแปลง URL prefix ไปเป็น URL ของรีเวิร์สเว็บพร็อกซี่ซึ่งเป็นชื่อเว็บเซิร์ฟเวอร์จริงที่ใช้ในการติดต่อสื่อสารกับไคลเอนต์



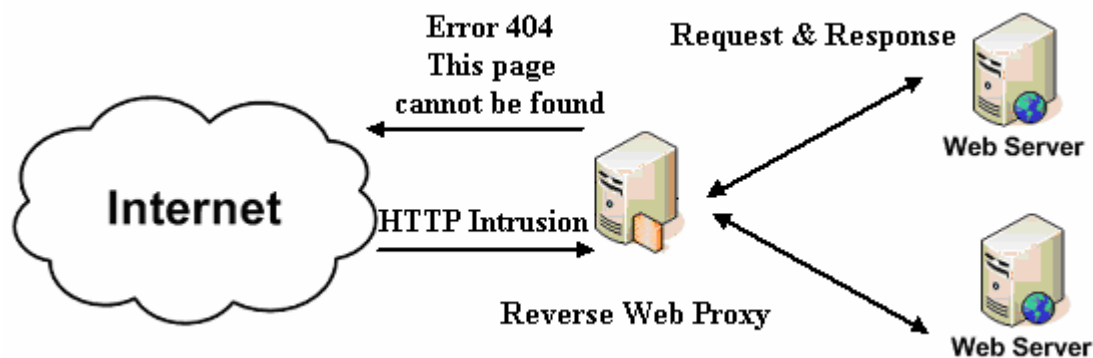
รูปที่ 2.5 การทำงานของรีเวิร์สเว็บพร็อกซี่

ในการใช้งานรีเวิร์สเว็บพร็อกซี่นั้นจะมีการใช้งานร่วมกับไฟร์วอลล์โดยมีการกำหนดกฎให้มีเพียงแต่ไอพีแอดเดรสของรีเวิร์สเว็บพร็อกซี่เท่านั้นที่สามารถติดต่อกับเว็บเซิร์ฟเวอร์ได้ ซึ่งหากมีการติดต่อสื่อสารเป็นการร้องขอจากไคลเอนต์มายัง URL ของรีเวิร์สเว็บพร็อกซี่ซึ่งเป็นทางที่ใช้ในการติดต่อกับเว็บเซิร์ฟเวอร์ รีเวิร์สเว็บพร็อกซี่ก็จะทำการตรวจสอบการร้องขอนั้นกับ prefix mapping ว่าจะต้องส่งการร้องขอนั้นให้กับเว็บเซิร์ฟเวอร์ใด จากนั้นจึงจะส่งการร้องขอนั้นไปยังไฟร์วอลล์เพื่อทำการส่งการร้องขอนั้นให้กับเว็บเซิร์ฟเวอร์

ทางฝั่งของเว็บเซิร์ฟเวอร์เมื่อประมวลผลของการร้องขอที่ได้รับจากไคลเอนต์เสร็จแล้วจะทำการส่งผลลัพธ์กลับไปยังไคลเอนต์ ก็จะต้องทำการส่งผ่านไปยังรีเวิร์สเว็บพร็อกซี่ก่อนเช่นกัน ซึ่งเมื่อรีเวิร์สเว็บพร็อกซี่ได้รับผลลัพธ์ที่จะส่งกลับไปยังไคลเอนต์ ก็จะนำไปตรวจสอบกับ reverse mapping และทำการเปลี่ยน URL และ HTTP header กลับเป็น URL ที่ใช้ในการติดต่อกับไคลเอนต์ก่อนที่จะส่งผลลัพธ์นั้นกลับไปยังไคลเอนต์ ซึ่งไคลเอนต์ก็จะมองเห็นว่าการร้องขอนั้นถูกตอบรับโดยรีเวิร์สเว็บพร็อกซี่ แต่แท้จริงแล้วถูกตอบโดยเว็บเซิร์ฟเวอร์

2.4.3 รีเวิร์สเว็บพร็อกซี่แบบปลอดภัย (Secure Reverse Web Proxy)

เป็นการใช้งานรีเวิร์สเว็บพร็อกซี่ให้มีความปลอดภัยในการใช้งาน โดยทำการตรวจสอบการร้องขอที่เข้ามาก่อนที่จะส่งต่อไปให้กับเว็บเซิร์ฟเวอร์ ว่าการร้องขอนั้นตรงกับรูปแบบการโจมตีหรือไม่ หากพบว่ามีการร้องขอที่ตรงกับรูปแบบการโจมตีก็จะทำการสกัดการร้องขอนั้นไว้ โดยอาจจะทำการเก็บบันทึกไฟล์และทำการส่งค่า page ที่เหมือน page ปกติเช่น *page Error 404 This Page can not be found* เป็นการตอบสนองที่เรียกว่า Silent Killer Operation



รูปที่ 2.6 การทำงานของรีเวิร์สเว็บพร็อกซีแบบปลอดภัย

2.5 ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์ (Intrusion Detection System)

ระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์นี้จะมีการเก็บข้อมูลของแพ็คเกจต่างๆ ที่เข้ามาสู่ระบบเครือข่ายแล้วนำมาวิเคราะห์เปรียบเทียบกับกฎต่างๆที่กำหนดไว้ รวมถึงนโยบายขององค์กร เพื่อตรวจสอบว่ามีสิ่งผิดปกติเกิดขึ้นกับระบบหรือไม่ หากเกิดสิ่งผิดปกติก็จะแจ้งเตือนไปยังผู้ดูแลระบบหรือเก็บไว้ในล็อกไฟล์ต่อไป

การตรวจจับผู้บุกรุกทางคอมพิวเตอร์สามารถแบ่งตามลักษณะของการโจมตีได้ 5 ประเภท

1. การพยายามเจาะเข้าไปทำการถ่ายเครือข่าย (Attempted break-ins)
2. การปลอมแปลงเพื่อเข้ามาโจมตีเครือข่าย (Masquerade attacks)
3. การอาศัยจุดบกพร่องของระบบรักษาความปลอดภัยเพื่อเจาะเข้าสู่เครือข่าย (Penetration of the security control system)
4. การโจมตีเพื่อปิดบริการ (Denial of service)
5. การสำรวจระบบ (System survey)

2.5.1 ระบบตรวจจับผู้บุกรุกที่ใช้งานในไฟร์วอลล์

สำหรับระบบตรวจจับผู้บุกรุกทางเครือข่ายที่สร้างขึ้นเพื่อใช้งานร่วมกับเพอร์ซันนอลไฟร์วอลล์นั้นมุ่งเน้นศึกษาในเรื่องของการออกแบบพัฒนาระบบตรวจจับการสำรวจระบบ และการโจมตีเพื่อให้ปิดบริการ ซึ่งเป็นลักษณะของการโจมตีระบบที่สำคัญและมีแนวโน้มเพิ่มขึ้นมากในปัจจุบัน มีรายละเอียดดังต่อไปนี้

1. การสำรวจระบบ

การบุกรุกเพื่อทำการสำรวจระบบเป็นเก็บข้อมูลของระบบ เพื่อใช้ในการโจมตีโดยข้อมูลที่ผู้โจมตีมักต้องการได้แก่ หมายเลขไอพีแอดเดรส ชื่อเครื่อง โครงสร้างทางเครือข่ายของระบบ

เป้าหมาย พอร์ตหรือบริการที่เครื่องเป้าหมายเปิด และระบบปฏิบัติการรวมทั้งเวอร์ชันที่ติดตั้งบนเครื่องเป้าหมาย สำหรับการสำรวจระบบที่สามารถทำการตรวจจับได้มีอยู่ 3 วิธีการสำรวจดังนี้

1.1 ปิงสวீป (Ping sweep)

การตรวจจับการปิงสวี่ปทำได้โดยการตรวจสอบดูแพ็คเก็ต ICMP Request (Type8) ที่เข้ามายังระบบ หากมีแพ็คเก็ตลักษณะนี้จำนวนมากเกินกว่าที่กำหนดและมีปลายทางแตกต่างกันจะสามารถสรุปได้ว่าในเครือข่ายกำลังถูกสำรวจโดยการปิงสวี่ป

1.2 การสแกนพอร์ต

การตรวจสอบการสแกนพอร์ตทำได้โดยการตรวจสอบแพ็คเก็ตที่มีหมายเลขพอร์ตปลายทางในลักษณะกระจาย คือแพ็คเก็ตมีการส่งไปยังเครื่องๆ เดียวแต่มีการส่งไปยังพอร์ตต่างๆ กันเป็นจำนวนมากเกินกว่าที่กำหนดจะสามารถสรุปได้ว่ากำลังถูกสำรวจโดยการสแกนพอร์ต

1.3 การตรวจสอบระบบปฏิบัติการ

การตรวจจับการตรวจสอบระบบปฏิบัติการสามารถตรวจสอบได้จากการพิจารณาแฟล็กที่ถูกส่งไปในชั้นที่ซีพีของทุกๆพอร์ตว่าเป็นแพ็คเก็ตแบบผิดปกติหรือไม่ กล่าวคือในแต่ละสเตทของที่ซีพีโปรโตคอลนั้นจะมีรูปแบบแฟล็กตายตัวอยู่ ตามสถานะปัจจุบันของสเตทของที่ซีพี เช่น หากต้องการเริ่มต้นการเชื่อมต่อโปรโตคอลที่ซีพี จะต้องกำหนดให้แฟล็ก ACK เป็น 1 ส่วนแฟล็กอื่นต้องเป็น 0 หรือหากต้องการยกเลิกการเชื่อมต่อโปรโตคอลที่ซีพี จะต้องกำหนดให้แฟล็ก FIN เป็น 1 ส่วนแฟล็กอื่นเป็น 0 เป็นต้น

วิธีการตรวจจับที่ใช้ในโปรแกรมนั้นได้ทำการตรวจจับโดยหากแพ็คเก็ตมีแฟล็ก ACK และ FIN เป็น 1 พร้อมกันในแพ็คเก็ตเดียวกัน จะระบุว่าเป็นการบุกรุกโดยการสำรวจเพื่อระบบปฏิบัติการเนื่องจากการตรวจจับวิธีนี้เป็นกรณีมาตรฐานที่โปรแกรมที่ทำการระบุระบบปฏิบัติการทุกโปรแกรมจะนำมาตรวจสอบ และเป็นแฟล็กที่ไม่สามารถเกิดได้จริงเมื่อมีการใช้งานโปรโตคอลที่ซีพี

2. การโจมตีเพื่อให้อุปกรณ์บริการ

การโจมตีเพื่อให้อุปกรณ์บริการคือการกระทำใดๆ ที่ทำให้ระบบเป้าหมายไม่สามารถให้บริการบางอย่างได้ หรือไม่สามารถให้บริการต่อไปได้ การโจมตีระบบเครือข่ายคือการสร้างภาระให้กับเครือข่าย แบ่งได้ 3 ประเภทดังนี้

2.1 การส่งแพ็คเก็ตปริมาณมาก

การตรวจจับแพ็คเก็ตที่เข้ามาในลักษณะนี้ทำได้โดยใช้การนับจำนวนแพ็คเก็ตที่เข้ามาสู่ระบบโดยพิจารณาจากแอดเดรสปลายทาง (Destination Address) ในแพ็คเก็ตเฮดเดอร์ของไอพี หากเป็นค่าเดียวกันในนับจำนวนแพ็คเก็ตที่เข้ามาในช่วงเวลาหนึ่ง แล้วนำค่าที่ได้มาเปรียบเทียบกับค่าที่ยอมรับได้ หากค่าที่นับได้มากกว่าค่าที่ยอมรับได้ ก็ให้แจ้งเตือนแก่ผู้ดูแลระบบ หรือเก็บไว้ในล็อกไฟล์ ความยากของการวิเคราะห์แบบนี้อยู่ที่การหาค่าที่ระบบยอมรับได้ เพราะขึ้นอยู่กับปัจจัย

หลายประการ เช่น ความเร็วของเครือข่าย ความเร็วของหน่วยประมวลผลเครื่อง ปริมาณหน่วยความจำในเครื่อง เป็นต้น

การหาค่าที่ระบบยอมรับได้นี้ สามารถทำได้โดยการเชื่อมต่อกับระบบที่วิเคราะห์ จากนั้นหาจำนวนแพ็คเก็ตที่เข้ามาในระบบในลักษณะการใช้งานปกติของแต่ละช่วงเวลา จากนั้นนำค่าสูงสุดที่ได้มาเป็นค่าที่ระบบยอมรับได้ ค่าที่ผ่านการวิเคราะห์และยอมรับได้โดยปกติมีค่าประมาณประมาณ 20,000 - 30,000 แพ็คเก็ตต่อวินาที

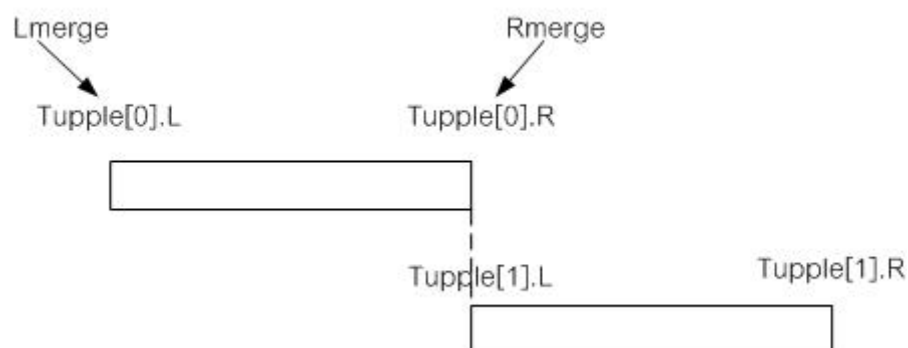
2.2 ความผิดปกติของแฟล็กเมนต์

การตรวจสอบความผิดปกติ ของแฟล็กเมนต์มีขั้นตอนก่อนข้างซับซ้อน ซึ่งแยกอธิบายตามประเภทของความผิดปกติได้ ดังต่อไปนี้

2.2.1 การส่งแพ็คเก็ตที่มีลำดับผิดปกติ และ แพ็คเก็ตที่มีขนาดหลั่มล้ำกัน

การวิเคราะห์ความผิดปกติของแพ็คเก็ตในลักษณะนี้ต้องวิเคราะห์หลังจากกระบวนการรีแอสเซมเบิลไปแล้ว ดังนั้นจึงนำบัพเฟอร์เข้ามาช่วยในการเก็บข้อมูล เพื่อนำมาวิเคราะห์ ดังนี้

- Fragment Buffer คือ บัพเฟอร์ที่เก็บข้อมูลในการวิเคราะห์ของแพ็คเก็ตไอพีและข้อมูลที่จำเป็นอื่นๆไว้ ได้แก่ Source_IP, Destination_IP, Identification, Protocol, Sec, PointArray และ Array_Fragment การเก็บข้อมูลจะเก็บในลักษณะของโครงสร้างข้อมูลแบบลิงคัลลิสต์



รูปที่ 2.7 แสดงการเก็บข้อมูลของตัวแปร Tuple

การเก็บข้อมูลใน Fragment Buffer มีตัวแปรต่างๆ ที่จัดเก็บดังตารางที่ 2.3 และการเก็บข้อมูลส่วน Fragment โดยจะเก็บเป็น Array มีข้อมูลตามตารางที่ 2.4

ตารางที่ 2.3 แสดงโครงสร้างการเก็บข้อมูลของ Fragment Buffer

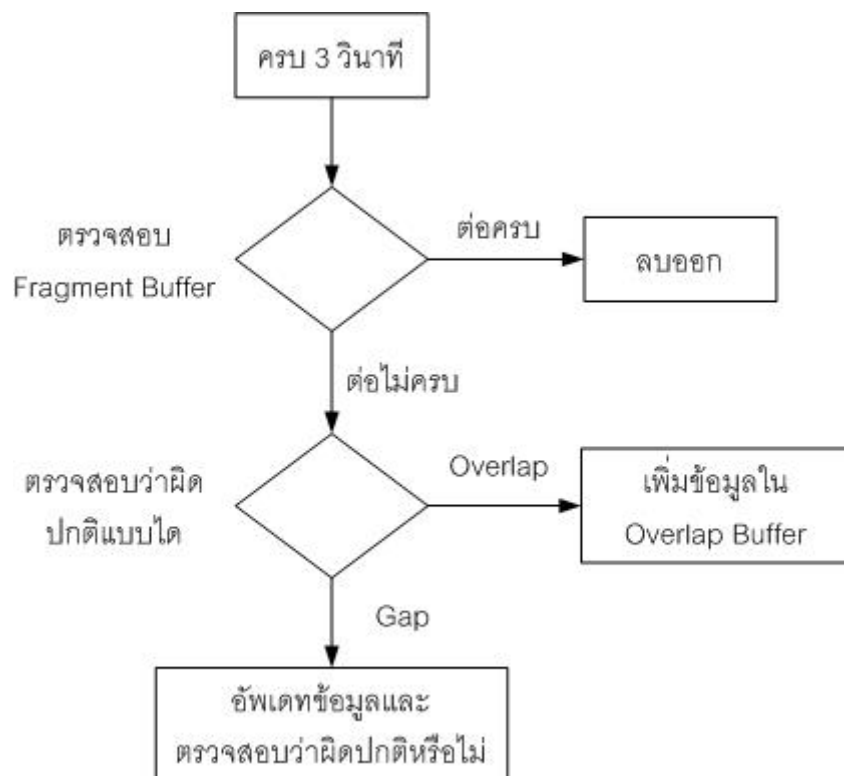
IP_Src	IP_Dst	Identification	Protocal	Sec	Pointarray	Arrau_Fragment
--------	--------	----------------	----------	-----	------------	----------------

ตารางที่ 2.4 แสดงโครงสร้างการเก็บข้อมูลของ Fragment

Flag_U	Flag_D	Flag_M	Offset	Size_Data
--------	--------	--------	--------	-----------

- Overlap Buffer เป็นบัฟเฟอร์ที่เก็บข้อมูลเมื่อตรวจพบว่าการเหลื่อมล้ำของแพ็คเก็ต มีการเก็บในลักษณะของลิงค์ลิสต์
- Gap Frame Buffer คือ บัฟเฟอร์ที่เก็บข้อมูล เมื่อตรวจพบว่าการประกอบเฟรมไม่ได้ในลักษณะมีช่องว่างระหว่างแพ็คเก็ต มีการเก็บในลักษณะของลิงค์ลิสต์

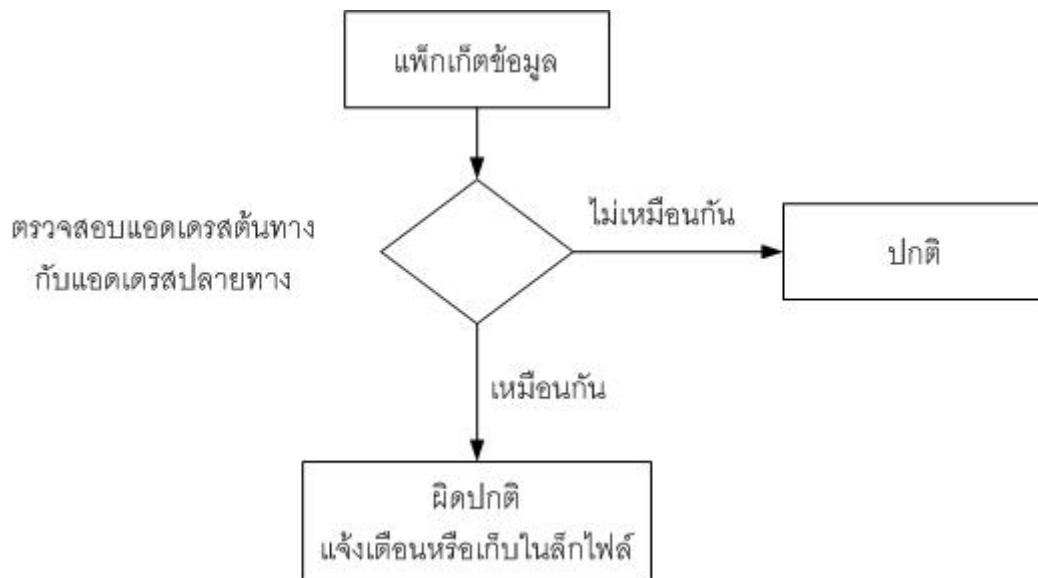
ในการวิเคราะห์จะใช้บัฟเฟอร์เหล่านี้ร่วมกันโดยเก็บข้อมูลแพ็คเก็ตที่เข้ามาทั้งหมดลงใน Fragment Buffer หากแพ็คเก็ตที่ส่งมาสามารถรวมกันได้ก็รวมกันเป็นแพ็คเก็ตเดียวที่ต่อเนื่องกัน แต่หากรวมกันแล้วเกิดความผิดปกติ ให้แจ้งมายัง Overlap Buffer หรือ Gap Frame Buffer แล้วแต่ความผิดปกติที่เกิดขึ้น หากไม่มีความผิดปกติเกิดขึ้นเมื่อครบ 3 วินาที โปรแกรมจะตรวจสอบ Fragment Buffer ว่าหากมีแพ็คเก็ตใดยังไม่ได้ประกอบหรือประกอบไม่ครบให้เก็บไว้ใน Overlap Buffer หรือ Gap Frame Buffer และเมื่อครบ 3 วินาที ข้อมูลใน Overlap Buffer หรือ Gap Frame Buffer นี้จะออกมาที่หน้าจอเพื่อแจ้งให้ผู้ดูแลระบบทราบหรือเก็บไว้ในล็อกไฟล์เพื่อบันทึกความผิดปกติที่เกิดขึ้น หากไม่มีความผิดปกติใดๆเกิดขึ้นและแพ็คเก็ตเหล่านั้นสามารถประกอบเป็นเฟรมได้อย่างถูกต้อง ให้ลบเฟรมเหล่านั้นออกจากบัฟเฟอร์ทันที เพื่อไม่ให้สิ้นเปลืองเนื้อที่ในการจัดเก็บ



รูปที่ 2.8 แสดงการตรวจสอบความผิดปกติในการทำแฟร็กเมนต์

2.2.2 การส่งแพ็กเก็ตแบบวนรูป

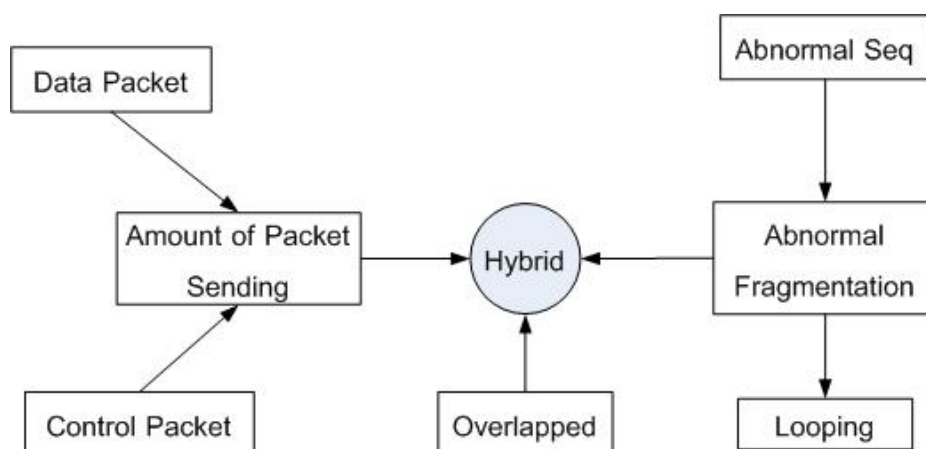
การส่งแพ็กเก็ตแบบวนรูปนี้สามารถทำได้โดยการเปรียบเทียบค่าไอพีแอดเดรสต้นทาง และ ไอพีแอดเดรสปลายทางของเซดเดอร์แพ็กเก็ต หากค่าไอพีต้นทางและไอพีปลายทางเป็นค่าเดียวกัน แสดงว่ามีความผิดปกติเกิดขึ้นเพราะทำให้เกิดการส่งในลักษณะวนรูป ซึ่งมีขั้นตอนดังรูปที่ 2.9



รูปที่ 2.9 แสดงการตรวจสอบแพ็กเก็ตที่ส่งแบบวนรูป

2.3 การโจมตีแบบผสม (Hybrid)

การวิเคราะห์แพ็กเก็ตประเภทนี้ให้นำวิธีการวิเคราะห์ที่กล่าวข้างต้นมาใช้ร่วมกัน เนื่องจากเกิดวิธีการที่ผสมผสานกันระหว่างวิธีต่าง ๆ ที่ได้กล่าวมาแล้ว ซึ่งสามารถแยกวิเคราะห์ออกเป็นแต่ละแบบหรือ วิเคราะห์รวมกันก็ได้ดังขั้นตอนในรูปที่ 2.10



รูปที่ 2.10 แสดงแผนภูมิแสดงประเภทของการโจมตีเพื่อให้ปิดบริการแบบผสม

2.5.2 ระบบตรวจจับผู้บุกรุกที่ใช้งานในไฟร์เบรก

สำหรับไฟร์เบรกซึ่งเป็นรีเวิร์สเว็บพรีอ็อกชั่นนั้นจะมีการใช้งานของระบบตรวจจับผู้บุกรุกเพื่อตรวจสอบในระดับของแอปพลิเคชันเลเยอร์ที่เป็นการติดต่อกับเว็บเซิร์ฟเวอร์ที่อยู่ข้างหลัง รีเวิร์สเว็บพรีอ็อกชั่นสำหรับในส่วนนี้ได้มีการใช้โปรแกรม Snort_inline ซึ่งเป็นโปรแกรมระบบตรวจจับและป้องกันผู้บุกรุก (Intrusion Prevention System IPS) คือโปรแกรมระบบตรวจจับผู้บุกรุกทางเครือข่ายคอมพิวเตอร์ที่สามารถป้องกันการโจมตีได้ทันทีที่ตรวจพบ เป็นการเพิ่มความสามารถในการดักจับแพ็คเก็ตให้กับโปรแกรมระบบตรวจจับผู้บุกรุกเดิมนั่นเอง

การติดตั้ง การตั้งค่าการใช้งาน การทดสอบการใช้งานจะกล่าวถึงในบทของการออกแบบการพัฒนา และการทดสอบการใช้งานต่อไป